



0. 인증·보안·세션 전체 구조

담당: 이정하

기능 개요

- 인증/보안/세션 전 영역 담당
 - 웰컴·튜토리얼(비로그인 온보딩), 회원가입, 이메일 로그인/로그아웃
 - Google/GitHub 소셜 로그인(OAuth), 비밀번호 재설정
 - 인터셉터 기반 세션 재검증, Remember-me(자동 로그인) 쿠키 발급/복원
 - 관리자/사용자 role 기반 라우팅
- 핵심 설계 방향
 - 로그인 실패 사유(이메일 미존재 vs 비밀번호 오류)를 밖으로 구분해 주지 않는다 — 계정 탐색(enumeration) 차단
 - 세션은 로그인 시점 스냅샷을 그대로 믿지 않고, 보호 경로 접근 시마다 DB로 재검증한다
 - 자동 로그인·비밀번호 재설정 토큰은 DB에 원문을 남기지 않는다(서명/해시만 저장)
 - 회원가입·소셜가입은 중간에 실패해도 반쪽짜리 계정이 남지 않는 원자적 구조로 설계
- DB/트랜잭션
 - 회원가입 시 `users` → `user_credentials` → `user_settings` → `user_learning_profile` 4개 테이블을 하나의 트랜잭션으로 생성

사용 기술 및 핵심 메커니즘

- 세션/인증: `HttpSession` 기반 서버 세션(`SessionUser` 를 세션 attribute로 저장), Spring MVC `HandlerInterceptor` 체인으로 인증 파이프라인 구성(`WebMvcConfig`)
- 비밀번호: `BCryptPasswordEncoder` 해시 저장, `@StrongPassword` 커스텀 validation 어노테이션 + 공통 `PasswordPolicy` 클래스

- **자동 로그인(Remember-me):** 자체 쿠키 스킴 `userId.version.HMAC-SHA256(userId:version)` — 토큰 테이블 없이 서명 검증
- **비밀번호 재설정:** `SecureRandom` 256bit → URL-safe Base64 토큰 발급, DB에는 SHA-256 해시만 저장
- **소셜 로그인(OAuth):** Google/GitHub OAuth2 authorization code flow, `state` 파라미터로 CSRF성 위조 요청 차단
- **기타:** `BusinessException` + `ErrorCode` 기반 예외 처리(`AUTH_INVALID_CREDENTIALS`, `AUTH_SUSPENDED` 등), open redirect 방지용 내부 경로 화이트리스트(`safeRedirect`)

인증 파이프라인 전체 구조

로그인 여부만으로 접근을 판단하지 않고, **인터셉터 등록 순서 자체가 보안 정책**이 되도록 설계했다. remember-me 복원이 가장 먼저 실행되고, 그 뒤로 게스트 전용 → 로그인 필수 → 관리자 전용 순서로 검사한다.

```

요청
└─ RememberMeInterceptor    (쿠키 있으면 세션 복원 시도, 전 경로)
    └─ GuestOnlyInterceptor  (/login, /signup, /password/** → 로그인 상태면 role별 홈으로 튕김)
        └─ LoginRequiredInterceptor (/learning/**, /exams/**, /settings/**, /mypage → 매 요청 DB 재검증)
            └─ AdminRequiredInterceptor (/admin/**, /api/admin/** → ROLE_ADMIN만 통과)
  
```

위치: `config/WebMvcConfig.java` 26~51행 (`addInterceptors`, 경로 목록 일부 축약)

```

registry.addInterceptor(rememberMeInterceptor)
    .addPathPatterns("/**").excludePathPatterns("/health");
registry.addInterceptor(guestOnlyInterceptor)
    .addPathPatterns("/login", "/signup", "/password/forgot", "/password/reset");
registry.addInterceptor(loginRequiredInterceptor)
    .addPathPatterns("/learning/**", "/exams/**", "/settings/**", /* ... */ "/mypage");
  
```

```
registry.addInterceptor(adminRequiredInterceptor)
        .addPathPatterns("/admin/**", "/api/admin/**");
```

기능별 상세 문서

각 기능별 상세 내용은 같은 레벨의 하위 페이지 참고:

1. 웰컴·튜토리얼
2. 회원가입·로그인 (이메일·소셜 OAuth)
3. 세션 재검증 인터셉터
4. Remember-me 자동 로그인·비밀번호 재설정